

Politique de journalisation, audit et traçabilité

1. Objectif

Garantir que toutes les actions et événements critiques de la plateforme sont journalisés, traçables et auditable afin d'assurer : - La sécurité des données - La conformité réglementaire - La détection et la gestion des incidents - La responsabilité et la transparence

2. Périmètre

Cette politique s'applique à : - Toutes les applications (web, mobile, back-end) - Base de données - API et intégrations externes - Composants IA et modules automatisés - Administrateurs et utilisateurs privilégiés

3. Événements à journaliser

- Connexions réussies et échouées
- Création, modification, suppression de données sensibles
- Changement de rôles et permissions
- Actions des administrateurs et des examinateurs
- Accès API critiques
- Actions des systèmes IA sur les données
- Erreurs applicatives critiques
- Tentatives d'accès non autorisées

4. Format et stockage des logs

- Format structuré (JSON ou équivalent)
- Horodatage UTC synchronisé (NTP)
- Journalisation immuable (WORM ou systèmes équivalents)
- Stockage chiffré au repos
- Segmentation par type et niveau de sensibilité

5. Sécurité et accès aux logs

- Accès limité aux responsables sécurité et auditeurs
- Authentification forte pour tout accès
- Journalisation des consultations de logs
- Protection contre altération et suppression non autorisée

6. Conservation et archivage

- Conservation minimale légale (ex : 5 ans pour données administratives)
- Archivage sécurisé hors ligne pour données sensibles
- Politique de purge automatique après délai légal

7. Supervision et alertes

- Détection automatique d'anomalies (intrusion, accès suspect, manipulation)
- Alertes en temps réel pour événements critiques
- Intégration avec SIEM / SOC (Security Operations Center) si disponible

8. Audit et revue périodique

- Audit interne annuel ou après incident critique
- Revue trimestrielle des accès aux logs
- Vérification de la complétude et de l'intégrité des journaux

9. Conformité et références normatives

- ISO/IEC 27001 & 27002 – Gestion des journaux et audits
- NIST SP 800-92 – Guide de journalisation
- NIST SP 800-53 – Audit et traçabilité
- RGPD – Principes de responsabilité et traçabilité

10. Responsabilités

- RSSI / Responsable sécurité : définition et supervision
- Administrateurs systèmes : maintien des journaux et contrôle d'accès
- Auditeurs internes : revue régulière et rapport d'audit
- Direction de la plateforme : validation des politiques et suivi des recommandations

11. Mise à jour

- Révision annuelle ou après tout changement significatif dans l'architecture ou la réglementation
- Archivage de toutes les versions de la politique

Document de référence interne pour la traçabilité et l'audit de la plateforme de gestion numérique des auto-écoles et examens.